# 보안 특강: 내 비서를 지키는 최소한의 방어선

OpenClaw.ai 기초 1부 마스터 클래스

# Chapter 1

OpenClaw가 기본적으로

제공하는

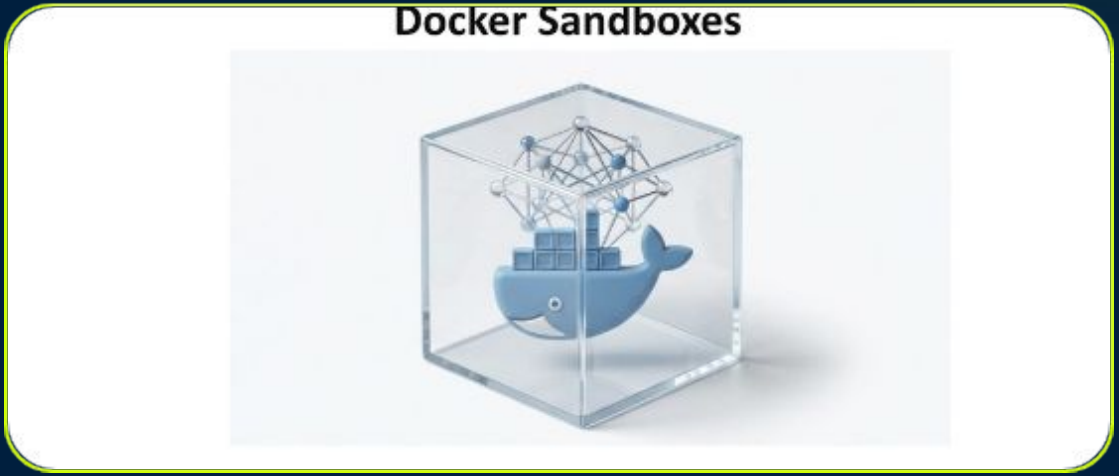
**핵심 보안 요소**의 이해

# Docker: 첫 번째 보안 격리막

### 서버와 브라우저의 신뢰 관계

OpenClaw는 실행 환경에 따라 신뢰 수준을 엄격히 구분합니다.

- **로컬 실행 (Native):** PC 본체를 신뢰 기기로 간주하여 비교적 완만한 보안 정책을 적용합니다.
- **컨테이너 실행 (Docker):** 격리된 네트워크 환경을 구축하며, 외부 호스트 접속을 '신뢰할 수 없는 기기'로 인식하여 **수동 페어링**을 강제합니다.



# 4중 보안 인증 아키텍처

### 접속용 토큰

.env 파일을 통해 비밀번호 역할을 하는 게이트웨이 토큰을 관리합니다.

### 디바이스 페어링

단순 암호를 넘어 승인된 기기만 접속 가능한 2중 인증을 지원합니다.

### Salted Hash

토큰 정보는 Salt가 적용된 해시값으로 암호화되어 안전하게 저장됩니다.

### LAN Binding

서비스 노출을 최소화하여 로컬 네트워크 내부의 안전을 도모합니다.

# Root of Trust: 신뢰의 연쇄 작용

01

### 토큰과 페어링의 유기적 관계

게이트웨이 토큰은 시스템 전체 **신뢰의 뿌리**입니다.

- 페어링된 기기 정보는 마스터 토큰을 기반으로 보호됩니다.
- 토큰이 변경되면 기존의 신뢰 관계는 **무효(Invalid)** 처리됩니다.
- 보안 사고 발생 시 즉각적인 **재페어링(Re-pairing)**으로 안전을 확보합니다.

# Chapter 2

현시점에서 우리가 경계해야

할

**취약한 보안 요소** 분석

# 보안의 빈틈: 인간과 기술의 한계

### GitHub 설정 파일 노출

실수로 .env 파일을 공개 저장소에 공유할 경우, 토큰과 API 키가 전 세계에 노출될 수 있습니다.

### 평문(Plain Text) 저장

현재 OpenClaw는 API 키를 암호화하지 않은 텍스트 형태로 저장하고 있어, 물리적 접근에 취약할 수 있습니다.

# Chapter 3

취약점을 보완하는

실전

**방어 전략 및 사용자**

**습관**

# 프로덕션 환경을 위한 3대 수칙

### 옵션 최적화

실무 환경에선 --allow-unconfigured 옵션을 제거하여 '일단 실행'을 차단하세요.

### OS 환경변수 활용

토큰을 파일이 아닌 OS 환경변수에 등록하여 프로젝트 내 명시적 노출을 피하세요.

### 주기적 기기 점검

devices list 명령어로 승인되지 않은 기기가 있는지 수시로 확인하세요.

# API 키 유출 방어 전략

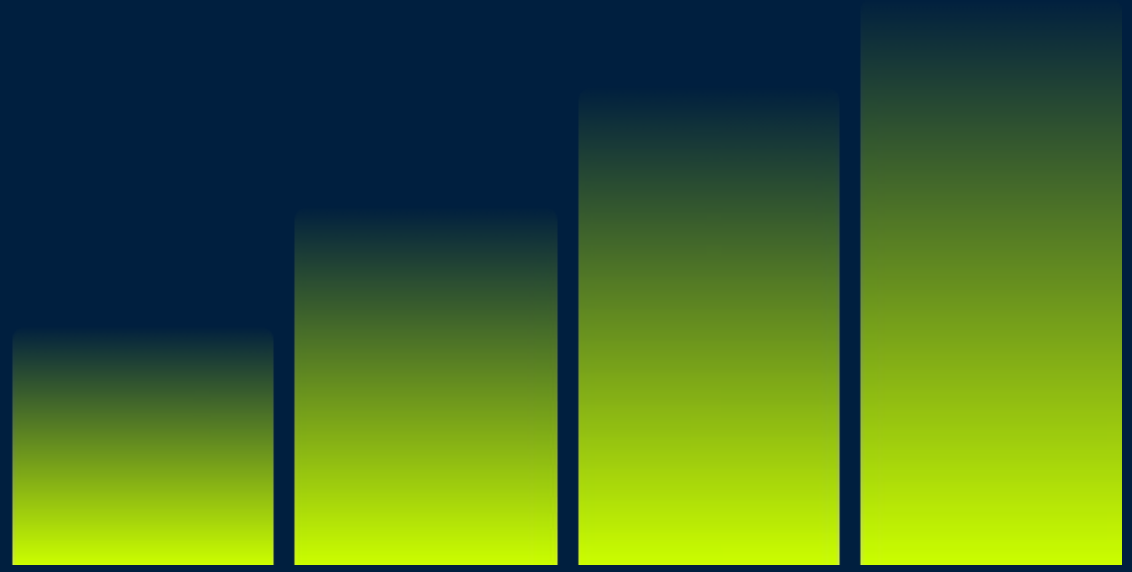
| 방어 레이어 | 실행 액션 | 보안 효과 |
| --- | --- | --- |
| **과금 방지** | 구글 클라우드 서비스(GCP)에서의 예산 알림 & 할당량 설정 | 키 유출 시 '과금 폭탄' 미연에 방지 |
| **접속 제한** | GCP 콘솔 IP 화이트리스팅(IP Whitelisting) | 허용된 서버 IP 외 사용 원천 차단 |
| **긴급 대응** | 의심 시 즉각 키 삭제 및 재발급 | 유출된 키의 물리적 효력 즉시 제거 |

# 미래 전략: 물리적 흔적 지우기

### 인프라 아키텍처의 진화

물리적 저장 공간의 취약점을 극복하기 위해 다음과 같은 방향을 지향할 수 있습니다.

- **Ramdisk 활용:** 휘발성 메모리 내 실행으로 물리적 흔적 완전 제거
- **Secret Manager:** 클라우드 전용 보안 키 관리 서비스 연동



"가장 강력한 보안은 도구가 아니라

**사용자의 습관**에서 나옵니다."

기술보다 중요한 것은 시스템의 원리를 이해하고 관리하는 **여러분의 정성**입니다.